جامعة التقنية والعلوم التطبيقية
University of Technology and Applied Sciences
صحار
Suhar

Department of Information Technology

Midterm Exam

Academic Year: 2022-2023 **Semester: Spring**
Course Code: CSSY2108 **Date: 10/4/2023**
Course Title: Introduction to Security **Time: 11:00-11:40**

Student Name: _____

Student ID: _____ **Group No.:** _____

Instructions for students:

This exam lasts for **40 hour** and is worth **20% towards** your final mark for **CSSY2108**
Please, place all bags, folders and other belongings at the front or back of the room.
Please **TURN OFF** your mobile phones and leave them at the front or back of the room.
Please **DO NOT TALK** during the exam without permission from the invigilators.
Use **PEN** only to write your answers. **Calculators could be used.**
Hand in the exam paper to your invigilators, at the end of the exam.

For Examiner use only

	Mark allotted	**Mark scored**					
Section A Multiple choice (1 x 5)	**5**						
Section B Short Answer (4x2.5)	**9**	B1	B2	B3	B4	B5	
Section C long Answer (5x1)	**6**	C1					
Total	**15**						

Examiner: ..... Signature: .....

Section A: Multiple Choice Questions (5 Marks, each Question 1 mark)

A1. In The incident response process, the Attempt to remove the effects of the issue from our environment is:

a. Containment
b. Eradication
c. Recovery
d. Preparation

A2. Which of the following model implements a combination of DAC and MAC and it is primarily concerned with the confidentiality of the resource in question?

a. The Biba model
b. Discretionary access control model
c. Brewer and Nash Wall model
d. Bell - LaPadula Model

A3. _____ is a reactive tool; in that it allows us to view the record of what happened after it has taken place. In order to immediately react to something taking place, we would need to use a tool more along the lines of an IDS/IPS.

a. Logging
b. Auditing
c. Identity
d. Availability

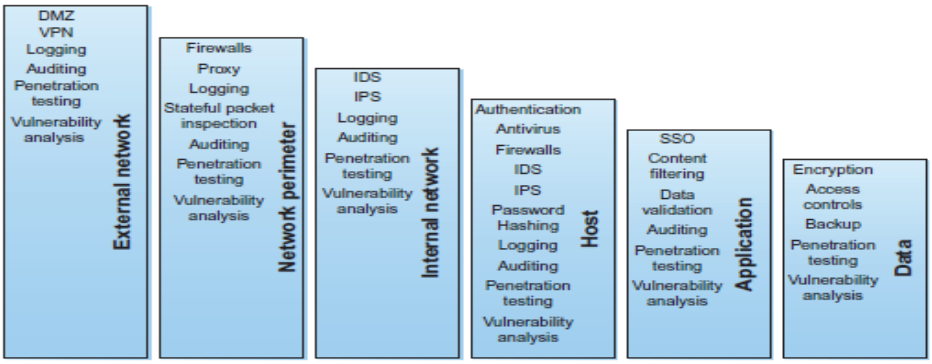
A4. Which one of the following is NOT the symmetric key algorithm?

a. RSA
b. DES
c. 3DES
d. AES

Section B: Short Answer Question: (9 Marks, each Question 3 marks) Please Answer only 3 Questions:

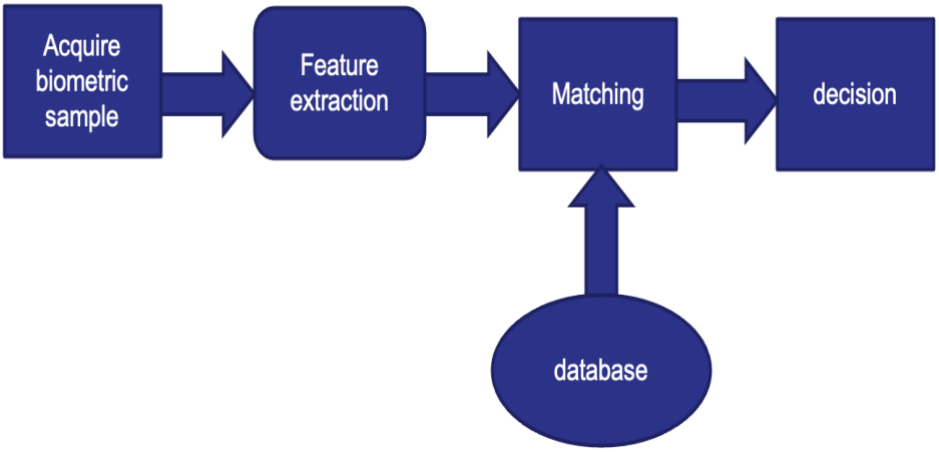
B1. Define Defense in depth and give an example.

Defense in depth is a strategy to formulate a multilayered defense that will allow us to still achieve a successful defense should one or more of our defensive measures fail.



B2. Define Biometrics and Illustrate how it works using a diagram.

Biometrics are automated methods of recognizing a person based on physiological or behavioral characteristics.



B3. As an admin, you are designing employee access control for files security,

Grade-1 employees having classified as having equal permission for **HR documents**,

Grade-2 employees have been given permission to access the **Finance documents**.

Using the above scenario, fill the below table with what type of access control**(Read/Write/Both(Read&Write))** could be applied for **Grade-1** and **Grade-2 employees.**

Grade-1	**HR documents**
Grade-2	**Finance documents**

	HR documents		**Finance documents**	
Grade-1	**Bell La Padula**	Read&Write	**Bell La Padula**	Read No Write
Grade-2	**Biba model**	No Write Read	**Biba model**	Read&Write.

B4. An employee denies receiving an email from the Owner of a company,

a. What ensures that they behave in accordance with the rules as they relate to security, business conduct, ethics, and so on.? (1.5 Marks) **Accountability**

b. What is the term we used to pervent such an unexpected reply from the employee? (1.5 Marks) **Non-repudiation**

B5. What are the benfits of Digital signatures?

- **enable detection of changes to the message contents**
- **ensure that the message was legitimately sent by the expected party**
- **prevent the sender from denying that he or she sent the message, known as nonrepudiation.**

Section C: Long Answer: (5 Marks) Please Answer <u>only One</u> Question:

C1.Answer the following,

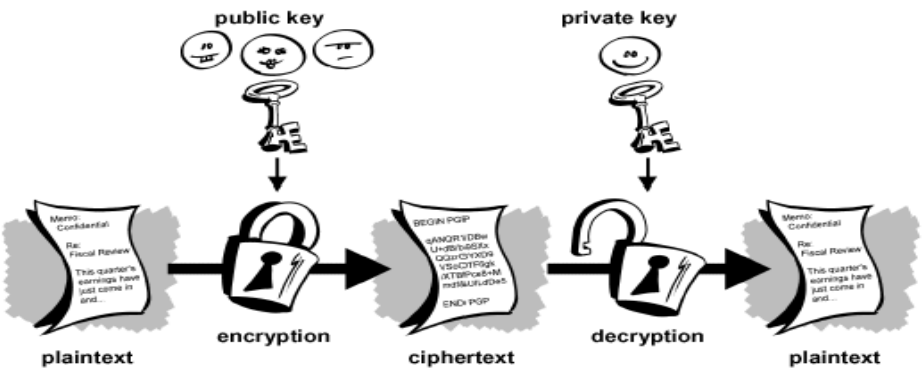
C1.1 Describe the Penetration Test. (2 Marks)

1. As a more active method of finding security holes, we may also wish to conduct penetration testing.
2. Penetration testing, although it may use vulnerability assessment as a starting place, takes the process several steps further.
3. When we conduct a penetration test, we mimic, as closely as possible, the techniques an actual attacker would use.
4. We may attempt to gather additional information on the target environment from users or other systems in the vicinity, exploit security flaws in Web-based applications or Web-connected databases, conduct attacks through unpatched vulnerabilities in applications or operating systems, or similar methods.
5. Generally a penetration test is more useful for a mature origination that wants to validate its security architectures and response capabilities.

C1.2 When Bob wants to send a message to Alice, he uses public key cryptography. Explain the public key cryptography using a block diagram. (3 Marks)

Alice and Bob

- Here Bob wants to send a message to Alice. Bob will encrypt the message with the public key of Alice and sends it to Alice. Alice will decrypt the same message with her private key.
- The private key must be the combination pair of its public key. Then only this will satisfy.
- In this case there is no authenticity
- i.e. anybody can send the message to Alice. Alice cannot predict this has been send from Bob



C2.Answer the following question:

C2.1 Answer the below question using the exhibit of File System ACL. **(3Marks)**

```
-rw-------  1 root root      1024 Oct  4 12:46 .rnd
drwxr-xr-x  3 root root      4096 May  9  2010 .subversion
```

1. Describe the .rnd file permissions
2. Describe the .subversion file permissions
3. Whether both files are folders. Give your answer. **.subversion is folder**

C2.2 Read the threats from the following table and complete them by identifying the type of threat(interception, interruption, modification, and fabrication), and the type of security breach(availability, confidentiality, and integrity). **(3 Marks)**

	Type of threat	Breach of?
The unauthorized change of Firewall system settings	**Modaification**	**integrity**
an attacker gain access to critical data in your computer	**intercption**	**Confidentiality**
an attacker adds false sales records to a database	**Fabrication**	**integrity**